

Table of Contents

Sovereign Policy Token Transactions (SPT-Txn): A Privacy-Preserving, Crypto-Agile Authorization Framework for Regulated and Agentic Systems

Author: Rudolf J. Coetzee · Violet Sky Security SEZC (Cayman Islands SEZC) **ORCID:** 0009-0009-6557-8843 **Status:** Working paper / preprint (v2 draft), for deposit on **Zenodo** (citable DOI; the project's existing preprints are 10.5281/zenodo.19299787 and 10.5281/zenodo.18917439). Companion to — and deliberately distinct in scope from — the IETF Internet-Draft draft-coetzee-oauth-spt-txn-tokens. **Date:** June 2026

Scope & audience. This is the comprehensive **framework** paper (preprint / grant / NIST-engagement audience), not the IETF Internet-Draft. The I-D specifies only the transaction-token protocol; this paper covers the full architecture, the design alternatives considered, the cryptographic choices and their measured trade-offs, the post-quantum migration plan, and the regulatory/standards context. Coined terms are anchored to their base standards on first use (§10).

Abstract

Every regulated interaction — opening an account, transacting a tokenised asset, authorising an AI agent to act on a person's behalf — today requires identity and eligibility to be re-verified from scratch, at every platform, at a cost of tens of dollars and days of latency per check. The data exhaust of that model is a standing breach liability, and it does not survive the move to autonomous agents, where the accountable human dissolves within one or two delegation hops.

SPT-Txn is an authorization framework that verifies once and proves everywhere. A user holds a **Compliance Attestation Token (CAT)** — a W3C Verifiable Credential, issued by a regulated KYC/compliance provider, that binds zero-knowledge-provable compliance attributes to a **zkDID** commitment. A platform evaluates a zero-knowledge proof of the CAT against a representation-agnostic **policy object** and, on a match, issues a scope-bounded **Capability Token (CT)**; an AI agent receives a strictly attenuated, delegation-depth-bounded CT carrying an immutable **humanAnchor** back to the accountable person. Each action emits a transaction-bound **SPT-Txn token** (≈ 30 s lifetime, sender-constrained per DPoP), and every step is recorded to a tamper-evident audit trail. No personally identifiable information is transmitted or stored at the verifying party; compliance is proven, not disclosed.

The framework is **blockchain-agnostic** (a ledger adapter; XRPL and others are deployment targets, not dependencies), carries no native token, and is **crypto-agile by**

design: algorithm identifiers travel in every token and the Trust Registry — not the token header — governs algorithm acceptance, enabling a hybrid classical/post-quantum migration without a flag day. We report a working reference implementation hardened on OpenBSD (pledge/unveil, privilege separation), a live two-party FATF Travel Rule deployment carrying a payload-level ZK attestation over the inter-VASP Travel Rule Protocol, measured cryptographic benchmarks driving the primitive choices (Poseidon2 over MiMC; BN254 vs BLS12-381; Groth16 vs PLONK), and a CycloneDX Cryptographic Bill of Materials aligned to US Executive Order 14409 (2026).

1. Introduction

1.1 The problem

Three capabilities are each individually mature and collectively unintegrated: attribute-based access control (ABAC) gives fine-grained, policy-driven authorization but assumes a centralized, online policy decision point; self-sovereign identity (SSI) and Verifiable Credentials give user-controlled, privacy-preserving identity but no on-line policy enforcement and no transaction binding; and capability/transaction tokens (object-capability security, the OAuth Transaction Tokens work) give scoped, delegable authority but carry no identity provenance and no compliance semantics. No deployed system composes them into a single chain that is simultaneously privacy-preserving, regulator-satisfying, offline-verifiable, and accountable across organisational and agentic boundaries.

The cost of that gap is concrete. Repeated KYC/AML verification is a multi-billion dollar annual tax with onboarding abandonment rates that platforms quantify in the tens of percent. The PII accumulated to satisfy it is a perpetual breach surface. And the model fails outright for the agentic economy: when an AI agent transacts on a human's behalf, neither regulators nor counterparties can reconstruct who authorised what — a direct obstacle to obligations such as EU AI Act Article 14 (effective human oversight), enforceable from August 2026.

A fourth pressure is now statutory. US Executive Order 14409, *Securing the Nation Against Advanced Cryptographic Attacks* (2026-06-22), mandates federal migration to post-quantum cryptography (NIST FIPS 203/204/205), sets contractor deadlines (2030/2031), and directs CISA and NIST to publish Cryptographic Bill of Materials (CBOM) guidance within 270 days. Any authorization infrastructure built today must be crypto-agile and inventory-able by construction.

1.2 Contributions

This paper makes the following contributions:

1. **A composed token chain** — CAT (compliance attestation) → CT (capability) → SPT-Txn (transaction) — that unifies SSI credentials, ABAC policy evaluation, and capability/transaction tokens, with an explicit ABAC→TBAC boundary: policy is

evaluated **once** at issuance; thereafter every token is enforced cryptographically with no policy engine consulted (offline-verifiable).

2. **The CAT + attribute model** (§2.3): a precise account of where compliance attributes live (proven into the CAT, never disclosed), including a **static / dynamic guardrail** that prevents stale-compliance authorization for volatile attributes (AML-risk, sanctions).
3. **An immutable humanAnchor** — a zkDID commitment propagated unchanged across the chain — giving Sybil-resistant, privacy-preserving human accountability for agentic action (EU AI Act Art. 14).
4. **zkDID and zkDNS** (§3, §4): zero-knowledge identity that breaks the cross-verification correlation attack, and a two-layer naming/discovery design (decentralized name→key binding; private resolution) analysed against centralized DNS, DNSSEC, ENS, and Handshake.
5. **A measured cryptographic design** (§5): empirical benchmarks on the reference host driving the choices (Poseidon2 vs MiMC; BN254 vs BLS12-381; Groth16 vs PLONK), a lifetime-triaged **hybrid post-quantum migration** plan, and a CycloneDX CBOM aligned to EO 14409.
6. **A working, hardened reference implementation** with a live, two-party privacy-preserving FATF Travel Rule deployment (IVMS101 + SD-JWT + ZK over the OpenVASP Travel Rule Protocol), security-audited on OpenBSD.

1.3 What this paper is not

It is not the protocol specification (that is the IETF I-D). It does not claim post-quantum security today — it claims a defined, measured migration path. It treats on-chain instantiations (e.g. a policy expressed as an NFT) as **informative** deployment options, never as normative or as tradeable assets, to remain clear of securities and money-transmission classification (§9).

2. Architecture and the token chain

2.1 Actors

Five roles: the **user** (a person, or an AI agent acting for one); the **KYC/compliance provider** (a regulated issuer of CATs); the **platform** (bank, exchange, RWA venue, AI operator — the relying party and CT issuer); the **Trust Registry** (the authority on which issuers and algorithms are accepted); and **SPT-Txn** as neutral infrastructure in the middle. No party holds the user's PII except the issuing KYC provider, under a lawful-access escrow (§5, §9).

2.2 The three tokens (locked vocabulary)

- **CAT — Compliance Attestation Token.** A W3C Verifiable Credential [VC-DATA-MODEL], serialized as an SD-JWT VC [SD-JWT-VC], issued once by a KYC provider after verifying the user's attributes, bound to the user's zkDID. The user holds it and reuses it across platforms with no document re-submission.

- **CT — Capability Token.** A capability token (object-capability lineage; the draft's primary primitive) conveying a scope-bounded authorization, issued by a platform when a zero-knowledge proof of the CAT satisfies the platform's policy. A *root* CT sets the maximum scope; *delegated* CTs (e.g. to an agent) are strict subsets with bounded delegation depth, carrying the humanAnchor forward.
- **SPT-Txn token.** A transaction token [TXN-TOKENS] bound to one transaction context and sender-constrained per DPoP [RFC9449], ≈30 s lifetime, carrying the Travel Rule attestation where applicable. The token actually presented at the resource.

2.3 The CAT + attribute model

Attributes are **inputs to** the CAT, not its contents. KYC level, jurisdiction, and accredited/eligibility status (durable) are verified once and bound at CAT issuance; AML-risk and sanctions status (volatile) are sourced from a DID-anchored attribute oracle. The CAT carries *selectively-disclosable compliance claims and proofs that policy is satisfied — never the raw values*.

Static / dynamic guardrail. Durable attributes are bound at CAT issuance. Volatile attributes **MUST NOT** be frozen into the long-lived CAT; they are re-proven at CT issuance and again at SPT-Txn minting against the oracle's committed state, under a policy maximum-proof-age. This yields real-time revocation by updating the feed without revoking the credential, and closes the stale-compliance hole (a now-sanctioned party holding a still-valid capability).

The flow: KYC issues the CAT → the platform's PDP evaluates a ZK proof of the CAT against a composable, jurisdiction-aware **policy object** (the ABAC→TBAC boundary) → a scope-bounded CT is issued in milliseconds → an agent receives a delegated CT carrying the humanAnchor → each action emits an SPT-Txn token → all recorded to a tamper-evident audit trail. (Full diagram and term definitions: docs/GLOSSARY.md.)

2.4 Deployment targets (blockchain-agnostic)

The framework binds no logic to a specific ledger; a ledger adapter abstracts the anchoring of attestations, audit roots, and registry state, so a chain is a *target*, never a dependency. Deployment targets include the **XRP Ledger (XRPL)** — the primary integration and grant target, where SPT-Txn complements XRPL's on-ledger Credentials/DID with this off-ledger privacy and FATF Travel Rule layer and anchors audit roots to the ledger — alongside EVM-compatible chains, **Hedera** (Consensus Service for the tamper-evident audit trail), XDC (RWA and trade finance), Algorand, and Substrate parachains. No native token is introduced on any of them; the framework's revenue and trust models do not depend on one.

3. zkDID — zero-knowledge decentralized identity

3.1 The correlation problem

A conventional Decentralized Identifier [DID-CORE] is revealed during presentation: even when attributes are proven in zero knowledge, the verifier learns *which DID* is asserting them. That identifier is a correlation handle — it links a subject’s activity across verifications, platforms, and time, reconstituting the surveillance surface that selective disclosure was meant to remove. For a system that must satisfy data-minimisation duties (e.g. GDPR) while proving regulated facts, a stable, linkable identifier in every interaction is a liability.

3.2 The interim construction

SPT-Txn’s interim zkDID, implemented in the reference POC, is a hiding-and-binding commitment used as the **humanAnchor**:

$\text{humanAnchor} = H(\text{identity_material}, \text{randomness}) \text{ over BN254}$

where H is the shared ZK-friendly hash (§5.2, Poseidon2), computed natively and proven in-circuit by the *same* function — so the token’s humanAnchor is exactly the value a holder proves knowledge of, not a separate digest. **Fresh randomness is drawn per CAT issuance**, so a subject’s commitments are unlinkable across tokens; the commitment circuit proves knowledge of (identity_material, randomness) behind the public anchor without revealing either. This is the algebraic-commitment / anonymous-credential lineage (Pedersen commitments; BBS+; AnonCreds; zk-cred constructions), specialised to a single accountable-human anchor that propagates immutably from CAT through CT to SPT-Txn. The interim is self-sufficient — it delivers the essential privacy property using only the project’s own primitives, with no external dependency — though in the POC the identity material is a deterministic test principal; production binds it to a verified biometric uniqueness proof (§3.5).

3.3 Identity-method-agnostic: the adapter and the .zkdid production layer

What the interim does *not* provide is the full DID-method apparatus: a did:zkdid: identifier, document, and resolution; issuer-authorised binding as a method (in the POC this is handled separately by the Trust Registry, §7); and a governed naming layer. These are supplied in production by **Toby Bolton’s .zkdid / .zkdns infrastructure**, the intended zero-knowledge identity and naming provider, with which SPT-Txn integrates.

Crucially, SPT-Txn treats zkDID as an **interface** — commit → prove → verify → bind — not a hard dependency. The interim commitment is one implementation of that interface; .zkdid is the production implementation, adopted behind the same interface with no change to the token chain. SPT-Txn is therefore **identity-method-agnostic**, completing a consistent design discipline across three axes: *ledger* (blockchain-agnostic; XRPL a target, not a dependency), *policy representation* (the representation-agnostic policy object), and *identity method* (zkDID behind an adapter). The framework runs today on its interim and

upgrades to .zkdid/.zkdns when that infrastructure is production-ready — a forward-compatibility guarantee, not a blocking dependency.

3.4 The revised trust geometry

zkDID relocates where trust sits. The root of trust remains the **regulated issuer** (a KYC/compliance provider certified by a regulatory trust registry, §7), but the issuer's *accountability* is decoupled from the subject's *traceability*: a regulator can audit the issuer; the issuer cannot surveil the user's downstream access; a verifier cannot correlate a subject across sessions. Lawful re-identification remains possible — but only via the escrow path (§5.5), under quorum/lawful process, never from the on-the-wire data.

3.5 Hard problems (stated, not waved away)

- **Sybil resistance** requires proving *one human* → *one anchor* without revealing the human — a **biometric uniqueness** layer: a fuzzy extractor yielding a stable secret from noisy biometrics, plus a nullifier for global one-enrolment-per-person, inside a secure enclave with attested liveness (never biometric hashes on-chain). The POC uses a placeholder; this is a first-class part of the .zkdid integration.
- **Issuer coercion.** ZK cannot protect against a compromised or coerced issuer fabricating credentials; high-stakes attributes need multi-issuer attestation and governance, not cryptography alone.
- **Proof freshness.** A proof over committed state carries a timestamp; the policy enforces a maximum proof age (§2.3), implying a subject liveness requirement.
- **Proof-system soundness.** Integrity rests on the proving system and its parameters; production requires audited circuits and a sound or transparent setup (§5.4).

4. zkDNS — naming and discovery, and the alternatives

4.1 The problem

Inter-VASP and agent-to-agent authorization needs a way to discover a counterparty and bind its **name** → **public key** / **service endpoint** with integrity, and to do so without (a) depending on a single seizable/censorable root and (b) leaking who is querying whom. The FATF Travel Rule ecosystem currently solves discovery with sender-provided addresses (the OpenVASP *Travel Address*) or a centralized directory (TRISA's Global Directory Service, GDS). Both reintroduce a trust chokepoint and offer no query privacy. zkDNS is the design we propose to close that gap; it is evaluated below against the established options.

4.2 Alternatives considered

Centralized DNS + the ICANN root. Ubiquitous and operationally mature, but the root zone is a single governance and seizure point, and classic DNS provides neither integrity nor confidentiality. Unsuitable as a trust anchor for adversarial, cross-jurisdictional compliance traffic.

DNSSEC. Adds origin authentication and integrity via a hierarchical chain of trust to the (still ICANN-governed) root, and DANE/TLSA can bind a key to a name. But DNSSEC provides **no confidentiality** — queries and responses travel in the clear — and inherits

the centralized root and CA-like operational complexity. zkDNS *complements* DNSSEC (a DNSSEC bridge is possible) rather than discarding it.

ENS. Decentralized name resolution on Ethereum; bridges existing DNS names via a DNSSEC `_ens` record. Excellent for Web3 addressing, but general-purpose, **not zero-knowledge** (registrations and resolutions are public on-chain — a correlation surface), and not scoped to compliance/VASP discovery.

Handshake. Replaces the ICANN root zone with a blockchain-governed root and a decentralized trust anchor — a genuine CA/root alternative. But it is a general-purpose TLD system, not ZK, and not a name→key binding for a curated compliance/VASP set.

Namecoin (.bit) was the first such system and is now throughput- and feature-limited. ICANN’s OCTO-034 documents the real hazards of alternative name systems (namespace collision, resolution ambiguity); we acknowledge these and scope zkDNS narrowly to avoid them (it is not a public TLD).

4.3 zkDNS Layer 1 — decentralized name→key discovery

zkDNS L1 is **not** a general naming system. It is a name→key/endpoint binding over a **decentralized, committed trust registry** of VASPs/agents (the same Merkle-committed, signed-root structure used for VASP membership in §6): a party proves in zero knowledge that a counterparty name is **registered and its key binding is valid, without revealing the namespace or which entry** it matched. This replaces the Travel Address / GDS chokepoint with a neutral, capture-resistant root, and complements DNSSEC where a DNSSEC bridge is desired. One line: *Handshake decentralizes the root; ENS resolves Web3 names; zkDNS adds ZK membership proofs over a compliance/VASP trust registry.*

4.4 zkDNS Layer 2 — private resolution

Even with a decentralized binding, *who resolves what* leaks a behavioural graph (which VASP is screening which counterparty, when). zkDNS L2 combines two established techniques: **ODoH** (Oblivious DNS-over-HTTPS, RFC 9230) proxy/target separation, so no single server learns both the querier’s identity and the query; and a **DECO-style** zero-knowledge lookup against the registry/oracle’s **committed state**, so a resolver proves a name → key (and live attribute) result without revealing the query. This is the same “blind query against committed state” primitive used for the dynamic attribute oracle (§5), unifying discovery privacy and attribute privacy under one construction.

The constructions in §4.3–§4.4 specify the *properties* SPT-Txn requires of a naming/resolution layer. In production these are provided by **Toby Bolton’s .zkdns infrastructure** (the companion to .zkdid, §3.3), integrated behind the same adapter; SPT-Txn’s interim VASP-registry membership proofs satisfy the L1 binding today, so the framework is not blocked on the external layer.

4.5 Threat model and open problems

The committed set’s authority must itself be bootstrapped (who may add a VASP) — addressed by the regulatory trust-registry governance of §7; namespace collision is avoided by scoping (no public TLDs); liveness and freshness of the committed root require

periodic signed publication; and the privacy of L2 degrades if the proxy and target collude. These are stated as limitations, not solved by fiat.

5. Cryptographic design, measured

Cryptographic choices here are **benchmarked on the reference host, not assumed**.

5.1 Circuits and commitments

Three Groth16 predicate circuits prove compliance facts while revealing nothing about the underlying data: an **identity-commitment** circuit (the holder knows the material behind the humanAnchor), a **threshold** circuit (a committed amount is at or above the FATF reporting threshold, amount hidden, range-checked to 64 bits), and a **VASP-membership** circuit (a counterparty is in the committed registry, which member hidden, via a Merkle authentication path). The native commitment hash and the in-circuit gadget are the *same function by construction* — so the token's humanAnchor equals the zero-knowledge-proven commitment, end to end.

5.2 ZK-friendly hash: MiMC → Poseidon2

The commitment/Merkle hash is the dominant circuit cost. We migrated from MiMC to **Poseidon2** and measured the effect on the reference host (gnark v0.15, Groth16):

Hash	Curve
MiMC	BN254
Poseidon2	BN254
MiMC	BLS12-381
Poseidon2	BLS12-381

(64-hash stress circuit, chosen to amplify the hash cost; production circuits are 661–5,305 constraints.) Poseidon2 is an unambiguous win — **–44 % constraints, –41 % prove, –44 % setup** vs MiMC, with identical proof size and verify. The production VASP circuit fell 5,305 → 3,001 constraints on migration. Poseidon2 is adopted; MiMC is the documented prior interim.

5.3 Elliptic curve: BN254 vs BLS12-381

The same benchmark quantifies the curve trade-off: **BLS12-381** (~128-bit margin) costs roughly **2× the prove and setup time and +49 % proof size (164 → 244 B)** versus **BN254** (~100-bit margin), with ~25 % slower verify. Because SPT-Txn proofs are **ephemeral** — verified once and discarded within the 30-second token lifetime — a ~100-bit *classical* attack on a proof whose value has already expired is not a realistic threat, and BN254 additionally offers EVM precompile compatibility. We therefore default to **BN254**, exposing **BLS12-381 as a configurable high-assurance option**. Both are pairing curves and **neither is post-quantum** (§5.6); the curve choice is a classical-margin/performance trade-off, not a quantum one.

5.4 Proving system: Groth16 vs PLONK

Groth16 gives the smallest, constant-size proofs (3 group elements) and fastest verify, at the cost of a **per-circuit trusted setup** — itself a trust assumption and an operational burden (the benchmark's 1–4 minute setups are per circuit). gnark also supports **PLONK**, whose universal/updatable setup amortises one ceremony across all circuits, reducing the trusted-setup attack surface without leaving the toolchain. We retain Groth16 for the POC (smallest proofs, mature) and document PLONK as the migration lever when reducing trusted-setup risk outweighs proof-size; this is independent of the post-quantum question.

5.5 Selective disclosure and escrow

Compliance claims are carried in an **SD-JWT** (selective disclosure): a surname can be revealed to a regulator while the given name, amount, and other fields stay hidden, each disclosed or withheld independently. The lawful-access **escrow** envelope (deanonymization under quorum/lawful process only) currently uses X25519/ECIES; its migration target is ML-KEM-768 (§5.6).

5.6 Post-quantum migration (triaged by lifetime)

NIST finalised the PQC suite in 2024 — **FIPS 203 ML-KEM, FIPS 204 ML-DSA, FIPS 205 SLH-DSA** — and the accepted transition is **hybrid** (classical || PQC, secure if either holds). US Executive Order 14409 (2026-06-22) makes this a deadline-bearing federal mandate (sensitive-system encryption by 2030, PQ authentication by 2031, contractor FIPS by 2030) and directs CBOM guidance.

We triage by **data lifetime**, because a future quantum adversary cannot retroactively forge a proof or token whose value already expired:

- **High priority — long-lived / retained.** Ed25519 on the **CAT, registry/trust-anchor roots**, and the **audit log**; X25519/ECIES on the **escrow** (5–7 yr retention; classic harvest-now-decrypt-later). Migrate to **hybrid Ed25519 + ML-DSA-65** and **hybrid X25519 + ML-KEM-768**.
- **Low priority — ephemeral.** Ed25519 on the **30-second SPT-Txn token** and the **Groth16 proofs** — migrate later.
- **PQ-OK already.** AES-256-GCM (NIST level 1); Poseidon2/SHA-256 (Grover-only).

Migration is enabled by **crypto-agility**: algorithm identifiers travel in every token/attestation, and the Trust Registry — not the token header — governs which algorithm a verifier accepts (downgrade-resistant), so a hybrid suite rolls per-issuer without a flag day. The MiMC → Poseidon2 migration (§5.2) is the proof-of-concept: a two-file, matched native/in-circuit change.

PQ-ZK is a roadmap, scoped honestly. Groth16/BN254 is pairing-based and **not post-quantum**. Transparent, post-quantum proving exists — STARKs (hash-based, no trusted setup) and lattice SNARKs (LaBRADOR, Greyhound) — but in different toolchains, with larger proofs and far less audit history. Because the proofs are ephemeral, migrating now would trade a fast, well-audited system for an immature one to defend a threat the proofs

do not face. We therefore state explicit **migration triggers** (proofs requiring long-term retention; maturation and audit of a PQ-ZK stack; regulatory requirement) rather than a premature rip-and-replace.

5.7 Cryptographic Bill of Materials

The full inventory — every primitive, where used, classical/quantum status, and migration target — is published as a **CycloneDX 1.6 CBOM** (docs/cbom.json, human-readable docs/CBOM.md), aligned to EO 14409's CBOM mandate. It is a *have-and-provide* artifact: available to partners and reviewers on request rather than broadcast (\$disclosure-posture), since for an open-source system it reveals nothing the source does not, but the commercial posture keeps the public surface to a one-line attestation.

6. Privacy-preserving FATF Travel Rule (deployed)

The FATF Travel Rule (Recommendation 16) requires that originator and beneficiary identity travel between VASPs for qualifying virtual-asset transfers. The two dominant protocols carry that data differently: **TRISA** (gRPC, protocol buffers) seals it in per-message encrypted Secure Envelopes; **OpenVASP TRP** (HTTPS/JSON) relies on transport-level mTLS and ships the IVMS101 identity in cleartext to the counterparty. TRP's gap is decisive for privacy: once the JSON arrives, the receiving VASP holds the full PII — a standing breach liability and a tension with data-minimisation law.

SPT-Txn closes that gap with a **payload-level zero-knowledge attestation** rather than trusted decryption. Instead of shipping the identity, the originator ships:

- the IVMS101 fields as a selectively-disclosable **SD-JWT** (reveal a surname to a regulator; keep the given name, account, and amount hidden); and
- three **Groth16 predicates** bound to the specific payment via its transaction-context hash: identity-commitment (the humanAnchor), amount $\geq$ the reporting threshold (amount hidden), and beneficiary-VASP registration (which VASP hidden).

The beneficiary learns *“this transfer is reportable, between registered VASPs, with an authenticated originator”* without receiving the amount or the identity fields it is not entitled to. Identity is carried in the **IVMS101** data model (the standard TRISA and TRP share), so the attestation interoperates with existing networks.

Topology and policy. Originator and beneficiary run as **separate services**: the originator holds the proving keys; the beneficiary holds **only the verifying key** — it can check an attestation but cannot forge one. A transfer with no SPT-Txn attestation (a plain-IVMS101 cleartext TRP transfer) is **refused** — this VASP requires payload-level privacy, not optionally. A **TRISA bridge** is designed (map the attestation into a Secure Envelope Payload, sealed to the recipient via KeyExchange/GDS), giving defence in depth: zero-knowledge for what the counterparty may compute, sealing for confidentiality at rest.

Deployed. This runs today on the reference host: two OpenBSD rc.d services (originator + beneficiary) behind relayd TLS, exchanging an attestation over a real TRP hop; the beneficiary returns *approved* disclosing only the surname and currency, with the amount

and other fields never transmitted. (internal/trp, internal/travelrule, internal/ivms101, internal/vasregistry, cmd/tr-svc; see docs/TRP-TRISA-INTEROP.md.)

7. Security and threat model

7.1 Adversaries and assets

Protected assets: the issuer signing keys (the root of the capability chain), the subject's identity/PII, and the integrity of the authorization chain. Adversaries considered: a network attacker on the inter-VASP path; a malicious or curious counterparty/verifier; a compromised individual service; a curious attribute oracle or directory; and a coerced issuer.

7.2 Per-layer

- **Token chain.** Scope can only narrow ($CT \subseteq$ parent enforced cryptographically at every hop); delegation depth is bounded; the humanAnchor is immutable; the SPT-Txn token is bound to one transaction context and sender-constrained (DPoP), so a captured token+proof is non-replayable (denied at enforcement step 5). The eight-step engine verifies the chain **offline** — no issuer contact, fail closed.
- **Attribute oracle / discovery.** Volatile attributes are re-proven against the oracle's *committed* state under a max-proof-age; blind, ODoH/DECO-style queries (§4.4) hide the query graph from the oracle.
- **Escrow.** Re-identification is possible only via the escrow path, under quorum/lawful process; the envelope uses a fresh ephemeral X25519 per seal, a random nonce, and AAD binding anchor|iss|iat; deanonymization requests carry a freshness window and replay guard.
- **Registry / discovery root.** Issuer authorisation is a registry lookup, not a query about the subject; the registrar rejects malformed and all-zero keys; registration is served only on an owner-only admin socket, never the edge.

7.3 Platform hardening (OpenBSD reference)

Every service applies real pledge(2) (syscall-set restriction) and unveil(2) (filesystem restriction) — e.g. the issuer can read only its own key path — runs under a dedicated least-privilege user, sits behind relayd TLS with a deny-by-default protocol, and uses OpenBSD signify keys (the loader rejects encrypted or checksum-invalid keys). A repeatable host audit (scripts/security-audit.sh) reports **FAIL=0**. The Go code is OS-portable (pledge/unveil is build-tagged); the production-Linux equivalents are seccomp-bpf ($\approx$ pledge) and Landlock ($\approx$ unveil).

7.4 Known limitations (stated honestly)

Per the full review (docs/SECURITY-REVIEW.md), all Critical and High findings are fixed and verified. Deferred, bounded items: **key encryption-at-rest** (keys are 0400/unveil-confined but unencrypted — fix via softraid/LUKS+TPM, HSM, or FROST); **Trust Registry persistence** (the mock registry reverts to revoked placeholders on restart — an interim re-registration script is in place); and the **trusted-setup risk** inherent to Groth16

(mitigated by PLONK/transparent options, §5.4). Production assurance is closed by an **independent ZK-circuit + protocol audit**, not by self-assertion.

7.5 Assumptions

Soundness of the proving system and its parameters; honesty (or multi-issuer attestation) of credential issuers — ZK cannot defend against a coerced issuer fabricating credentials; secure-enclave integrity for biometric uniqueness; and an honest-quorum for escrow deanonymization.

8. Related work and differentiation

Foundations SPT-Txn composes. Self-sovereign identity and W3C Verifiable Credentials / DID Core give user-controlled, privacy-preserving identity but no on-line policy enforcement or transaction binding; object-capability security (Biscuit, Macaroons) gives scoped, delegable authority but no identity provenance; the OAuth Transaction Tokens work gives transaction-scoped tokens but no compliance semantics; anonymous credentials (BBS+, AnonCreds) and soulbound tokens give unlinkable attributes but no composed ABAC/enforcement chain. SPT-Txn's contribution is the *composition* of these into one offline-verifiable, accountable chain.

vs DNA Protocol and XRPL ZK-identity. Recent XRPL-adjacent ZK-identity work (e.g. DNA Protocol) is consumer/genomic identity, **token-gated** (a native token is consumed to generate proofs) and built on its **own chain** bridged to XRPL. SPT-Txn differs on three axes that matter for institutional adoption: **no native token** (proofs run on the VASP's own infrastructure), **blockchain-agnostic** (no new chain; XRPL is a target behind an adapter), and **compliance-first** (complements FATF/regulation rather than an anti-institutional sovereignty pitch). On post-quantum, competitors advertise “quantum-ready”; SPT-Txn instead states a *measured* hybrid migration (§5.6) and is explicit that pairing-based Groth16 is not yet PQ — a more defensible claim now that EO 14409 makes “post-quantum” a checkable assertion.

vs git-id (MyNextID) — complementary, not competing. git-id answers *who an agent is*; SPT-Txn answers *what it may do* in a specific transaction. The gaps git-id leaves — no proof-of-possession, no cryptographic owner→agent binding, no transaction binding — are exactly what SPT-Txn's transaction-binding (TB) property and humanAnchor close. The natural composition: resolve agent identity via git-id → issue an SPT-Txn-scoped capability → enforce with the eight-step engine.

NIST alignment. SPT-Txn is the cryptographic primitive several NIST frameworks assume but do not specify: **IR 8587** (protecting tokens/assertions from forgery, theft, and misuse — the most direct fit, incl. demonstrated proof-of-possession and global revocation), **SP 800-207** (Zero Trust — per-transaction binding the PE/PA/PEP model presumes), **SP 800-204** series (microservices ABAC over JWTs), **SP 800-63** (digital identity / privacy), and **SP 800-162** (ABAC). The Travel Rule layer interoperates with **TRISA**, **OpenVASP TRP**, and **IVMS101**.

9. Regulatory and legal posture (informative)

This section is informative and not legal advice; classifications are jurisdiction- and structure-specific and require qualified counsel.

Securities (US Howey). The core primitives are compliance/authorization utilities — a CAT is a signed credential, a CT a scoped access token, an SPT-Txn token a per-transaction record — failing the profit-expectation prong, the practical death blow to a securities argument. The framework introduces **no native token**. Where a policy is instantiated on-chain (an optional, informative deployment detail), it is framed strictly as **compliance infrastructure, never an appreciating or yield-bearing asset**; the moment marketing implies investment return, that classification changes.

Money transmission. SPT-Txn operates at the **authorization layer and never touches the underlying value transfer** (“do not touch the money”) — the safe structural boundary under FinCEN’s MSB framework and state MTL regimes. Commercial fee structures (e.g. KYC-provider network access, policy-template licensing) are designed as **direct billing**, never as funds passing through the operator, to stay clear of the “accept-and-transmit” definition.

Licensing. Depending on activity and jurisdiction, **VASP registration** (e.g. Cayman Islands under the VASP Act / CIMA) and **MiCA CASP** authorisation (EU) may apply to the operating entity; a written legal opinion should precede commercial activity. The framework’s design (no custody, no native asset, authorization-layer only) is intended to minimise — not assert away — these obligations.

AI governance. The immutable humanAnchor provides the cryptographic evidence that a unique, accountable human authorised an AI agent and can be reconstructed under lawful process — the mechanism EU AI Act Article 14 (effective human oversight, enforceable August 2026) requires and that no current agent stack provides.

Post-quantum / federal. US Executive Order 14409 (2026) mandates PQC migration (FIPS 203/204/205) and CBOM guidance; SPT-Txn’s crypto-agility and published CBOM (\$5.6–\$5.7) align it to that trajectory ahead of the deadlines.

10. Terminology and standards mapping

SPT-Txn coins terms only where it adds a real profile, binding, or constraint, and **anchors each to its base standard on first use** — so novel work reads as an *extension* of the standards landscape, not a reinvention of it.

SPT-Txn term	Base standard / reference	What SPT-Txn adds
CAT — Compliance Attestation Token	W3C Verifiable Credentials 2.0; SD-JWT VC	compliance-attribute profile; zkDID binding; KYC-issued, reusable
CT — Capability Token	object-capability security (Biscuit, Macaroons); OAuth access token	humanAnchor propagation; scope-subset + delegation-depth invariants

SPT-Txn token	OAuth Transaction Tokens; DPoP (RFC 9449)	transaction-context binding; ~30 s TTL; Travel Rule attestation
zkDID	W3C DID Core; anonymous credentials (BBS+, AnonCreds)	ZK commitment so the DID itself is never revealed (unlinkable)
humanAnchor	SD-JWT key binding; proof-of-personhood	registered claim human_anchor; immutable cross-token propagation
Policy object	ABAC (NIST SP 800-162); XACML PDP/PEP	composable cross-jurisdiction policy; on-chain instantiation (informative)
zkDNS	DNSSEC; ENS/Handshake; ODoH (RFC 9230); DECO	ZK membership + private resolution over a compliance/VASP registry
Eight-step enforcement	NIST SP 800-207 Zero Trust (PE/PA/PEP)	offline, cryptographic per-step enforcement on the bound token

Primitives used as-is: Groth16/BN254 (and BLS12-381) zk-SNARKs; Poseidon2; Ed25519/X25519/ECIES; **ML-KEM (FIPS 203)** / **ML-DSA (FIPS 204)**; fuzzy extractors + nullifiers; **FATF Recommendation 16 + IVMS101**; OpenID4VCI for issuance. Aligns with **OAuth 2.0 Security BCP (RFC 9700)**, **NIST IR 8587**, and **SP 800-63**. (Full table and the anchor-on-first-use rule: docs/GLOSSARY.md §4.)

11. Conclusion and roadmap

SPT-Txn composes self-sovereign credentials, attribute-based policy evaluation, and capability/transaction tokens into a single chain that is privacy-preserving, accountable across organisational and agentic boundaries, and verifiable offline: **verify once, prove everywhere**. The design is disciplined along three axes of agnosticism — ledger (XRPL a target, not a dependency), policy representation, and identity method (zkDID behind an adapter) — so no part of the system is hostage to an external component or a single chain, and it carries no native token.

This is demonstrated, not asserted. The reference implementation is **deployed and security-audited (FAIL=0)** on a hardened OpenBSD host, with **real Groth16 zero-knowledge** (MiMC → Poseidon2, benchmarked), a **live two-party FATF Travel Rule** exchange over OpenVASP TRP carrying a payload-level ZK attestation, a published **CycloneDX CBOM**, and a measured, lifetime-triaged hybrid post-quantum migration plan aligned to US Executive Order 14409.

Roadmap. XRPL-native anchoring and XRPL Credentials integration; a biometric uniqueness layer (fuzzy extractor + nullifier + attested liveness) for Sybil resistance; adoption of the .zkdid/.zkdns production identity/naming layer behind the existing adapter; the hybrid PQ key migration; a containerised Linux production target

(seccomp/Landlock parity); end-to-end testing of agentic delegation (designed today, not yet tested); a persistent/chain-backed Trust Registry; and an independent ZK-circuit + protocol audit. SPT-Txn rides existing standards rather than replacing them — the posture that fits IETF (an OAuth Transaction Tokens extension), NIST engagement (IR 8587, SP 800-207/204/63/162), and the FATF Travel Rule ecosystem.

References

- W3C *Verifiable Credentials Data Model 2.0*; *Decentralized Identifiers (DID) Core 1.0*.
 - IETF *Selective Disclosure for JWTs (SD-JWT)* and *SD-JWT-based Verifiable Credentials (SD-JWT VC)*; *OAuth 2.0 Transaction Tokens* (draft-ietf-oauth-transaction-tokens); RFC 9449 *DPoP*; RFC 9700 *OAuth 2.0 Security Best Current Practice*; RFC 9230 *Oblivious DNS over HTTPS*.
 - NIST IR 8587 (Protecting Tokens and Assertions from Forgery, Theft, and Misuse); SP 800-207 / 800-207A (Zero Trust Architecture); SP 800-204 A/B/C (Microservices); SP 800-63-4 (Digital Identity); SP 800-162 (ABAC); SP 800-57 (Key Management); SP 800-133r3 (Key Generation).
 - NIST FIPS 203 *ML-KEM*; FIPS 204 *ML-DSA*; FIPS 205 *SLH-DSA*.
 - FATF *Recommendation 16* (Travel Rule); interVASP *IVMS101*; TRISA; OpenVASP TRP.
 - EU *Artificial Intelligence Act* (Reg. 2024/1689), Article 14; US *Executive Order 14409*, “Securing the Nation Against Advanced Cryptographic Attacks” (2026).
 - Grassi, Khovratovich, Roy, Schofnegger, *Poseidon2*; *LaBRADOR* and *Greyhound* (post-quantum lattice SNARKs); BBS+ signatures; Hyperledger AnonCreds.
 - Chainlink *DECO*; ENS; Handshake; Namecoin; ICANN *OCTO-034* (alternative name systems).
 - R. J. Coetzee, *SPT-Txn Transaction Tokens*, IETF Internet-Draft draft-coetzee-oauth-spt-txn-tokens; companion preprints, Zenodo 10.5281/zenodo.19299787 and 10.5281/zenodo.18917439.
-

Companion artifacts in this repository: docs/GLOSSARY.md (terminology + standards mapping), docs/CBOM.md + docs/cbom.json (Cryptographic Bill of Materials), docs/SECURITY-REVIEW.md, docs/TRP-TRISA-INTEROP.md, and the reference implementation under cmd/ and internal/.